

HTTPS — HTTP Secure

Servicio

HTTPS (HTTP sobre TLS/SSL)

Puerto por defecto

443/TCP

Descripción

HTTPS es la versión segura de HTTP que utiliza TLS (Transport Layer Security) para cifrar la comunicación entre cliente y servidor. TLS proporciona confidencialidad, integridad y autenticación del servidor mediante certificados digitales X.509. Es el estándar obligatorio para cualquier sitio que maneje datos de usuario, autenticación o información sensible. NIST recomienda exclusivamente TLS 1.2 y TLS 1.3 (SP 800-52 Rev. 2).

Riesgos de seguridad

- **Certificados inválidos, vencidos o autofirmados:** Un certificado no confiable permite ataques MITM si el usuario ignora las advertencias del navegador.
- **Versiones TLS obsoletas (SSLv2, SSLv3, TLS 1.0, TLS 1.1):** Estas versiones tienen vulnerabilidades conocidas (POODLE, BEAST, DROWN) y no deben usarse.
- **Suites de cifrado débiles:** Algoritmos como RC4, DES, 3DES o RSA sin Perfect Forward Secrecy (PFS) exponen el tráfico a descifrado retroactivo.
- **Mala configuración de HSTS:** Sin HSTS o con un `max-age` corto, los usuarios son vulnerables a SSL stripping en la primera visita.
- **Certificados emitidos a dominios incorrectos:** Wildcard mal implementados o Subject Alternative Names incorrectos pueden permitir suplantación.
- **Fijación de certificados ausente (Certificate Pinning):** En aplicaciones móviles, sin pinning un atacante puede usar certificados legítimos emitidos por CAs comprometidas.
- **Renegociación TLS insegura:** CVE-2009-3555 y variantes permiten inyección de datos en sesiones TLS.

Escenarios de ataque

1. **SSL Stripping:** El atacante usa herramientas como SSLstrip para degradar conexiones HTTPS a HTTP, interceptando datos sin que el usuario lo note.
2. **POODLE Attack:** Forzando un downgrade a SSLv3, el atacante puede descifrar cookies de sesión mediante un ataque de oráculo de padding.
3. **BEAST Attack:** Explotando TLS 1.0 con cifrado en modo CBC, el atacante puede recuperar datos cifrados mediante ataques de texto plano elegido.

4. **CA Compromise:** Si una Autoridad Certificadora es comprometida, el atacante puede emitir certificados válidos para cualquier dominio y realizar MITM.
5. **Certificado vencido ignorado:** Un usuario acepta la advertencia de certificado vencido, conectándose a un servidor potencialmente comprometido.

Mitigaciones recomendadas

- Usar exclusivamente **TLS 1.2 y TLS 1.3**; deshabilitar SSLv2, SSLv3, TLS 1.0 y TLS 1.1.
- Configurar únicamente **suites de cifrado seguras** con Perfect Forward Secrecy (ECDHE, DHE).
- Implementar **HSTS** con `max-age` mínimo de 1 año y directiva `includeSubDomains + preload`.
- Renovar certificados antes de su vencimiento; usar Let's Encrypt con renovación automática (certbot).
- Verificar configuración con herramientas como **SSL Labs Server Test** (ssllabs.com/ssltest/).
- Implementar **Certificate Transparency (CT)** y monitorear los logs de CT para detectar certificados fraudulentos.
- Configurar **OCSP Stapling** para verificación eficiente de revocación de certificados.
- En aplicaciones móviles críticas, implementar **Certificate Pinning**.

Nivel de exposición

Bajo (*Medio-Alto si la configuración TLS es incorrecta o los certificados no son gestionados adecuadamente*)

Referencias

- OWASP. *Transport Layer Security Cheat Sheet*.
https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- NIST. *SP 800-52 Rev. 2 — Guidelines for TLS Implementations*.
<https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final>
- RFC 8446 — *The Transport Layer Security (TLS) Protocol Version 1.3*. IETF, 2018.
<https://www.rfc-editor.org/rfc/rfc8446>
- CIS. *CIS Controls — Control 3: Data Protection*. <https://www.cisecurity.org/controls>